

ShopSphere

S23 - Security Hardening, Audit and Compliance Readiness

Backend + DB

Platform-Specific Sprint Planning Document

This document intentionally defines only the behavior and delivery scope of the selected platform. It does not mix implementation details from the other platforms.

1. Sprint Definition

Sprint: S23 - Security Hardening, Audit and Compliance Readiness

Platform: Backend + DB

Application: ShopSphere

Objective: Implement the backend and database boundary for Security Hardening, Audit and Compliance Readiness, including business rules, persistence and API behavior.

This sprint is complete only when the stated use cases, acceptance criteria and tests pass for this platform.

2. Business Use Cases

ID	Use Case	Actor	Precondition	Main Flow	Expected Result
UC-01	Audit critical mutation	Admin/system	Mutation is authorized	Record actor, action, object, old/new values where allowed, timestamp	Audit entry is immutable/traceable.
UC-02	Attempt privilege escalation	Attacker/tester	Low-privilege session	Call restricted API directly	Server rejects request and records security event where appropriate.

3. Detailed Implementation Plan

1. Audit product/price/inventory/order/refund/customer/role/config changes.
2. Review auth, authorization, validation, rate limiting, CORS, secrets and idempotency.
3. Run vulnerability and abuse testing.

4. Data / State / Contract Scope

- audit_logs

API / Integration Contract

- Feature APIs for this sprint, versioned under /api/v1.
- Every endpoint must define authentication, authorization, validation, error codes and request correlation.

5. Rules and Expected Behavior

- The platform must rely on the backend as the source of truth for business rules.
- Do not expose stack traces, secrets or internal implementation details to end users.
- Handle loading, empty, validation and error states explicitly.
- Requests that can be retried must be safe from duplicate side effects where the feature requires idempotency.
- Ownership and authorization must be checked server-side for protected data.

6. Acceptance Criteria

- Data model supports the required business relationships and constraints.
- API enforces authentication, authorization, validation and ownership where applicable.
- Business rules are server-authoritative.
- Transactions/idempotency/concurrency controls are used where the feature requires them.
- Controlled error codes and request correlation are implemented.

7. Test Cases

TC	Scenario	Expected Result
TC-S23-01	Privilege escalation	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-02	Object ownership bypass	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

TC	Scenario	Expected Result
TC-S23-03	Brute force	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-04	Rate limit bypass	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-05	Tampered token	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-06	Webhook replay	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-07	Sensitive error leakage	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.
TC-S23-08	Audit write failure	Operation is handled according to the defined business rule; no incorrect state or security leak is produced.

8. Sprint Exit Checklist

- Implementation completed only for this platform.
- All primary and negative use cases pass.
- API contracts are implemented/consumed as defined.
- Validation and authorization tests pass.
- Loading/empty/error handling is verified where applicable.
- No critical or blocker defect remains.
- Automated tests pass in CI.
- Documentation and contract changes are committed.

9. Out of Scope for This Document

- Implementation behavior of Customer Portal. That behavior belongs in the separate S23 document for that platform.
- Implementation behavior of Admin Portal. That behavior belongs in the separate S23 document for that platform.